

TSEC Risk & Cyber Advisory

www.tsecgrc.com | Info@tsecgrc.com

EXECUTIVE GUIDE

Cyber Risk Quantification Guide

TSEC Executive Guide Series | Understanding Cyber Risk in Financial Terms

Document Version	1.0
Effective Date	September 2026
Classification	PUBLIC
Prepared by	TSEC Risk & Cyber Advisory LLC
Review Cycle	Annual

© 2026 TSEC Risk & Cyber Advisory LLC. All rights reserved. Free to distribute unmodified; not for resale.

TSEC Technical Data Sheet

Every resource published in the TSEC Compliance Library™ includes this standardized technical data sheet, summarizing the resource's identity, scope, and intended use at a glance.

Library	TSEC Executive Guide Series
Framework	FAIR — Factor Analysis of Information Risk
Publication	Executive Guide
Category	Risk Management
Resource Name	Cyber Risk Quantification Guide
Document Type	Executive Guide
File Format	PDF / DOCX
Tier	Free Resource
Editable	No
Language	English
Target Audience	CEOs, CISOs, Compliance Leads, GRC Professionals
Cross-Mapped Frameworks	NIST CSF 2.0, ISO/IEC 27005
Approval Authority	TSEC Risk & Cyber Advisory LLC
Review Frequency	Annual
Owner	TSEC Risk & Cyber Advisory LLC
Version	1.0
Status	Published
License	TSEC Resource Library — free distribution, unmodified

Contents

TSEC Technical Data Sheet	2
Contents	3
About This Guide	4
01. Cyber Risk Quantification at a Glance	4
02. Why Quantify Cyber Risk?	4
03. From Qualitative to Quantitative Risk	4
04. Understanding FAIR.....	5
05. Loss Event Frequency	5
06. Loss Magnitude.....	6
07. Primary and Secondary Loss	6
08. Worked Example — Ransomware	7
Building the Estimate.....	7
09. Worked Example — Third-Party Breach.....	8
Building the Estimate.....	8
10. Understanding Uncertainty	9
11. Using Quantified Risk for Security Decisions.....	9
12. Executive Cyber Risk Reporting	10
13. Cyber Risk Quantification Readiness Assessment	10
14. Common Quantification Gaps	11
15. TSEC Cyber Risk Quantification Approach	11
16. From Risk Understanding to Risk Quantification	12
Revision History	12

About This Guide

This guide introduces cyber risk quantification (CRQ) using the FAIR (Factor Analysis of Information Risk) model — the leading standard for expressing cyber risk in financial terms. It is written for executives, boards, and GRC professionals who need to move beyond Low/Medium/High risk ratings toward numbers that support budget, insurance, and prioritization decisions.

This guide is educational and illustrative. It is not a substitute for a formal quantification engagement using an organization's own loss history, asset data, and calibrated subject-matter estimates. TSEC Risk & Cyber Advisory LLC is not a licensed actuary; figures in this guide, including the worked examples, are illustrative ranges for teaching purposes, not predictions for any specific organization.

01. Cyber Risk Quantification at a Glance

Cyber risk quantification is the practice of expressing cyber risk as a **probable frequency and probable financial magnitude of loss**, rather than as a subjective label. Instead of saying a risk is “High,” a quantified statement looks like: “We estimate a 20–40% annual probability of a ransomware loss event, with a resulting loss between \$750K and \$3.5M.”

That shift matters because dollars are a common language across security, finance, and the board — while “High” means something different to every person who writes it on a heat map.

02. Why Quantify Cyber Risk?

- **Budget justification** — defend security investment in the same financial terms as any other capital allocation decision.
- **Prioritization** — compare unrelated risks (ransomware, third-party breach, insider misuse) on a single scale instead of three separate Medium ratings that can't be ranked against each other.
- **Cyber insurance** — evaluate whether coverage limits and retentions are appropriate given modeled loss exposure.
- **Regulatory and board reporting** — respond to increasing expectations that boards oversee cyber risk in business terms, not only technical terms.
- **Control ROI** — compare the cost of a control against the reduction in modeled loss exposure it produces.

03. From Qualitative to Quantitative Risk

Traditional Low/Medium/High and red/yellow/green heat maps are fast and intuitive, but they carry well-documented weaknesses:

- **Inconsistent meaning** — two assessors rarely mean the same thing by “Medium,” and the same assessor is rarely consistent across assessments.

- **Not additive** — three “Medium” risks cannot be combined into a portfolio-level statement of exposure.
- **Compresses information** — a rare, catastrophic risk and a frequent, moderate one can both land on “High,” hiding the difference that matters most for decisions.
- **Can’t answer the question executives actually ask** — “How much could this cost us, and how likely is it?”

Quantitative risk analysis does not eliminate judgment — it still relies on subject-matter estimates — but it forces those estimates into explicit, testable, and comparable ranges instead of a single adjective.

04. Understanding FAIR

FAIR (Factor Analysis of Information Risk) is the industry-standard model for cyber risk quantification, maintained as the **Open FAIR** standard by The Open Group and the FAIR Institute. FAIR defines risk as the probable frequency and probable magnitude of future loss, and breaks that top-level statement into measurable factors:

Factor	Definition
Risk	The probable frequency and probable magnitude of future loss.
Loss Event Frequency (LEF)	How often a loss event is expected to occur in a given period, typically one year.
Loss Magnitude (LM)	The probable size of the loss, should an event occur.
Threat Event Frequency (TEF)	How often a threat agent is expected to act against an asset.
Vulnerability	The probability that a threat agent's action results in a loss event.
Primary Loss	The loss realized directly and immediately from the event itself.
Secondary Loss	Downstream loss realized only if secondary stakeholders react to the event — customers, regulators, investors, partners.

FAIR does not require exhaustive historical data before it can be used. It is designed to structure expert estimates — informed by whatever internal history, threat intelligence, and industry loss data exists — into a defensible model.

05. Loss Event Frequency

Loss Event Frequency (LEF) answers: **how often, per year, do we expect this scenario to result in a loss?** FAIR decomposes it into two components.

Component	Definition
Threat Event Frequency (TEF)	Contact Frequency (how often the threat agent comes into contact with the asset) multiplied by Probability of Action (how likely the agent is to act, given contact).
Vulnerability	The probability that the threat agent's action succeeds in causing a loss event — a function of the threat agent's capability relative to the organization's resistance strength (controls).

LEF = TEF × Vulnerability. Strengthening controls (raising resistance strength) lowers Vulnerability and therefore lowers LEF even when Threat Event Frequency — which is largely outside the organization's control — stays the same.

06. Loss Magnitude

Loss Magnitude (LM) answers: **if the event happens, how much does it cost?** FAIR recognizes six forms of loss, each of which can appear as primary loss, secondary loss, or both.

Loss Form	Description	Typically
Productivity	Reduced ability to deliver products or services during and after the event.	Primary
Response	Costs of managing the event — forensics, legal counsel, incident response, communications.	Primary
Replacement	Cost to replace damaged or destroyed assets, including data and infrastructure.	Primary
Fines and Judgments	Regulatory fines, legal settlements, and contractual penalties.	Primary or Secondary
Competitive Advantage	Loss of proprietary information or market position.	Secondary
Reputation	Reduced market value, customer attrition, or brand damage following disclosure.	Secondary

07. Primary and Secondary Loss

The distinction between primary and secondary loss is one of the most frequently misunderstood parts of FAIR, and it is where quantification most often goes wrong.

Dimension	Primary Loss	Secondary Loss
When it's realized	Immediately, as a direct consequence of the event.	Only if secondary stakeholders react — not guaranteed even when the event occurs.

Dimension	Primary Loss	Secondary Loss
Who is affected	The organization itself.	Customers, regulators, investors, partners, media.
How it's modeled	Estimated directly as a loss magnitude.	Estimated as a frequency (how likely stakeholders are to react) multiplied by a magnitude (how costly that reaction is).
Example	Incident response and forensics costs for a breach.	Regulatory fine and customer churn if the breach is disclosed and regulators or customers respond.

Because secondary loss is conditional, it is modeled as its own frequency — the Secondary Loss Event Frequency (SLEF) — multiplied by a Secondary Loss Magnitude (SLM). Skipping this distinction and treating every possible downstream cost as certain is the single most common source of inflated loss estimates.

08. Worked Example — Ransomware

Consider a mid-market company estimating ransomware risk against a single business-critical environment. The estimates below are illustrative starting ranges for teaching purposes; a real analysis would calibrate them against the organization's own control posture, industry threat data, and loss history.

Building the Estimate

- **Contact frequency** — ransomware operators broadly target the organization's sector and geography on an ongoing basis; contact is effectively continuous.
- **Probability of action** — opportunistic targeting means most contact does not escalate to a deliberate, sustained attempt against this specific organization.
- **Vulnerability** — depends on patch cadence, endpoint detection and response (EDR) coverage, email filtering, backup isolation, and privileged access controls. Weaker controls push Vulnerability — and therefore LEF — toward the top of the range.
- **Loss magnitude** — combines response and forensics costs, business interruption, potential ransom payment, regulatory exposure if data is exfiltrated, and reputational impact.

Parameter	Estimated Range	Basis
Loss Event Frequency (LEF)	0.20 – 0.40 events / year	Reflects sector-wide ransomware activity moderated by current control maturity (EDR, MFA, backup isolation).

Parameter	Estimated Range	Basis
Loss Magnitude (LM)	\$750K – \$3.5M per event	Primary loss (response, downtime, possible ransom) plus secondary loss (regulatory exposure, customer notification, reputational impact) if data exfiltration is confirmed.
Illustrative Annual Loss Exposure (ALE)	≈ \$150K – \$1.4M / year	Simplified range product (LEF × LM) for illustration. A full FAIR analysis runs a Monte Carlo simulation across the full distributions to produce a loss exceedance curve rather than a single range.

Read this as: “In a typical year, we expect a 20–40% chance of a ransomware loss event, and if one occurs, we expect it to cost between \$750K and \$3.5M.” That is a materially more decision-useful statement than “Ransomware risk: High.”

09. Worked Example — Third-Party Breach

Now consider risk introduced by a vendor with access to customer data — a scenario that is frequently underestimated because the controls involved sit outside the organization's direct control.

Building the Estimate

- **Contact and probability of action** — lower than a direct attack on the organization, since the threat agent targets the vendor, not the organization itself.
- **Vulnerability** — driven by the vendor's own security posture, the scope of data shared, and contractual controls — factors the organization can influence through due diligence but not directly control.
- **Loss magnitude** — dominated by secondary loss: breach notification obligations, regulatory exposure, contractual penalties, and customer attrition, even though the organization did not suffer the technical compromise itself.

Parameter	Estimated Range	Basis
Loss Event Frequency (LEF)	0.05 – 0.15 events / year	Lower than a direct attack scenario, reflecting indirect exposure through the vendor relationship rather than a direct attack surface.
Loss Magnitude (LM)	\$500K – \$5M per event	Primary loss is often modest (vendor management response effort); the wide range is driven by secondary loss — notification costs, regulatory fines, contract penalties, and customer churn — which vary sharply with data sensitivity and jurisdiction.

Parameter	Estimated Range	Basis
Illustrative Annual Loss Exposure (ALE)	≈ \$25K – \$750K / year	Simplified range product (LEF × LM) for illustration only.

The wide loss-magnitude range is itself informative: it signals that the organization's actual exposure depends heavily on contractual terms (who bears notification and liability costs) and on how sensitive the shared data is — both are levers the organization can negotiate before an incident, not after one.

10. Understanding Uncertainty

A point estimate (“this will cost \$1.2M”) implies false precision. FAIR analyses instead use **ranges and calibrated estimation**, typically expressed as a minimum, most likely, and maximum value, combined with an explicit confidence level.

Estimate Point	What It Represents
Minimum	A value low enough that the analyst is highly confident the true value will not fall below it.
Most Likely (Mode)	The single value the analyst judges most probable, informed by data and experience.
Maximum	A value high enough that the analyst is highly confident the true value will not exceed it.
Confidence Level	The stated probability that the true value falls within the min–max range — commonly 90% in FAIR practice.

These ranges feed a **Monte Carlo simulation**: thousands of randomized trials sampled from the input distributions, producing a full distribution of possible annual loss outcomes rather than a single number. The output is typically presented as a **loss exceedance curve** — showing, for any given loss amount, the probability that annual loss exceeds it. This is what separates a credible quantification from an authoritative-looking guess: the uncertainty is explicit and carried through the entire analysis, not hidden behind a single confident-sounding figure.

11. Using Quantified Risk for Security Decisions

- **Control cost-benefit** — compare a control's cost against the reduction in modeled loss exposure it produces (its effect on Vulnerability and therefore LEF, or on Loss Magnitude directly).
- **Prioritization across a risk register** — rank scenarios by modeled annual loss exposure instead of by qualitative severity, so a rare catastrophic risk isn't silently ranked the same as a frequent, minor one.

- **Insurance decisions** — compare the loss exceedance curve against policy limits and retentions to judge whether coverage is adequate, excessive, or misaligned with actual exposure.
- **Risk acceptance and transfer** — give risk owners a concrete number to accept, mitigate, or transfer, rather than a label that is difficult to defend or revisit.

Quantification does not replace judgment — it structures judgment so decisions can be revisited, challenged, and improved as better data becomes available.

12. Executive Cyber Risk Reporting

Quantified risk is only useful if it changes how the board and executive team make decisions. Reporting should translate the analysis into business terms without overstating its precision.

Do	Avoid
Present loss ranges with a stated confidence level.	Present a single point figure as if it were certain.
Compare modeled exposure against risk appetite or existing insurance coverage.	Present numbers in isolation, with no decision attached.
Show how modeled exposure changes if a proposed control is funded.	Present quantification as a one-time exercise disconnected from the budget cycle.
State the key assumptions and data sources behind the estimate.	Present the model as a black box the board is asked to trust without explanation.

13. Cyber Risk Quantification Readiness Assessment

A short self-assessment to gauge how ready an organization is to begin a credible quantification effort.

Readiness Area	Guiding Question
Asset Inventory	Can you identify which systems and data hold the greatest business value if compromised?
Incident History	Do you maintain records of past security incidents, including cost and downtime, even informally?
Control Visibility	Can you describe your current control posture (EDR, MFA, backup isolation, patch cadence) well enough to inform a Vulnerability estimate?
Financial Data	Do you have access to figures for downtime cost per hour, incident response spend, and regulatory exposure by data type?
Stakeholder Buy-In	Is there executive sponsorship to use quantified figures in budget and risk-acceptance decisions, rather than defaulting back to qualitative ratings?

Readiness Area	Guiding Question
Vendor Exposure	Do you know which vendors hold sensitive data and what contractual liability terms apply if they are breached?
Analytical Capability	Does anyone on the team have experience with FAIR, calibrated estimation, or Monte Carlo simulation — internally or through an advisor?

14. Common Quantification Gaps

Common Gap	Why It Undermines Quantification
No incident history retained	Without internal loss data, estimates rely entirely on industry data and expert judgment, widening uncertainty.
Treating quantification as a one-time exercise	Threat activity, controls, and asset value change; a model built once and never revisited becomes stale quickly.
Skipping calibration training for estimators	Uncalibrated experts are systematically overconfident, producing ranges that are too narrow to be credible.
Ignoring secondary loss	Treating every downstream cost as certain — or omitting it entirely — both distort the resulting exposure figure.
Presenting a single point estimate	Discards the uncertainty information that makes the analysis defensible and decision-useful.
No link back to the budget or risk-acceptance process	The analysis becomes an academic exercise instead of an input to an actual decision.

15. TSEC Cyber Risk Quantification Approach

TSEC Risk & Cyber Advisory LLC supports organizations in building a defensible FAIR-based quantification program — from initial scenario scoping through simulation and recurring executive reporting. The approach is designed to produce numbers that withstand scrutiny from the board, auditors, and insurers, not just numbers that look impressive in a slide.

Service Component	Description
Scoping & Data Collection	Identify priority risk scenarios and gather available loss history, asset, and control data.
FAIR Model Development	Build calibrated LEF and Loss Magnitude estimates for each scenario using the FAIR taxonomy.
Simulation & Analysis	Run Monte Carlo simulation to produce loss exceedance curves and annual loss exposure ranges.
Executive Reporting	Translate results into board-ready reporting tied to risk appetite, insurance, and budget decisions.

Service Component	Description
Ongoing Advisory	Recalibrate the model as controls, threats, and business context change.

16. From Risk Understanding to Risk Quantification

This guide introduces the concepts and structure behind cyber risk quantification. Applying them to your own environment — with calibrated estimates, full Monte Carlo simulation, and reporting built for your board — is the next step.

Explore the TSEC Cyber Risk Quantification Professional Pack™

A complete CRQ toolkit: FAIR scenario templates, a calibrated estimation workbook, simulation guidance, and board-ready reporting templates built on the framework in this guide.

Info@tsecgrc.com | www.tsecgrc.com

Revision History

Version	Date	Author	Summary of Changes
1.0	September 2026	TSEC Risk & Cyber Advisory LLC	Initial publication of the Cyber Risk Quantification Guide.